简行安全设计说明

本说明描述原型已实现的控制及其边界。核心原则是模型只提交草案，服务端依据当前用户、业务规则和本次授权决定是否执行。所有交易发生在合成金融沙箱。

1 权限边界

身份权限与操作分级分别控制。登录会话决定当前用户，资源访问再次检查所有权；demo管理员只增加演示管理能力，不能替其他用户授权金融交易。Agent角色决定能读取哪些上下文、提出哪些工具操作。实际账本写入必须经过业务网关与确定性服务，模型文字、研究报告、历史记忆均不能生成有效Grant。

操作级别	系统行为	示例
GREEN	在本人资源范围内自动执行已允许的操作	部分只读查询
YELLOW	展示业务详情，取得用户确认后执行	普通资金操作及需确认的设置
RED	核对业务详情并完成强验证后执行	大额或规则指定的敏感操作

具体级别以bank_rules.py中的操作定义及risk_tier计算为准。动态出金按当日累计出金加本次金额判断，超过100000分即1000元时为RED，否则为YELLOW；部分操作使用固定级别，实体卡申请另有规则。该阈值属于沙箱设定，不能解释为银行监管标准。产品风险等级与身份验证强度分别检查。

2 授权绑定与资金提交

授权指纹绑定用户、计划、版本、节点、操作、参数、风险等级及已验证对象。批准前回读当前业务条件，金额、对象或条件变化时旧指纹失效，要求重新核对。Grant有有效期和消费状态，不能无限复用。

提交前执行资金预检，事务内再次核验余额、预留、限额、测评和产品条件。金额使用整数分或定点口径。幂等键绑定执行节点，账本与回执记录实际结果。提交结果未知时先查原请求，不能生成一笔新付款来“重试”。

3 认证与凭证

密码使用随机盐和PBKDF2-HMAC-SHA256派生，比较使用常量时间函数。登录Token随机生成，数据库保存Token哈希，默认会话两小时后失效。TOTP密钥和用户模型API Key使用Fernet加密保存，本地auth.key必须单独保护。

本人认证器绑定密钥仅通过已登录用户的一次性绑定流程提供。演示验证码同时检查开关、用途和业务绑定，关闭演示开关后服务端拒绝生成与使用演示码。演示验证码不构成生产多因子认证。

4 模型与外部资料

工具名称、参数Schema和角色范围由服务端定义，调用前执行类型与业务校验。外部资料作为不可信证据处理，不能通过其中的指令改写工具权限或授权状态。公开资料缺少条件时明确说明未知，不能编造费率、到账日或收益。

敏感内容检测采用模式与字段检查，阻止密码、验证码和密钥进入普通业务参数及长期记忆。关键词过滤只能减少显性泄漏，不能声称识别所有变体，也不能替代所有权校验与执行网关。

用户在模型选择器输入自己的API Key后，Key加密保存在服务端，界面仅展示配置状态，业务模型与裁判Key隔离。模型服务仍会接收完成任务所必需的上下文，演示只使用合成数据；真实数据接入前必须另行进行数据最小化、服务商与出境合规评估。

5 记忆隔离

Chroma查询带权限元数据过滤，回读SQL原文时再次检查所有权、角色、版本与有效期。旧余额、旧授权和删除后的偏好不能恢复成当前可执行事实。任务状态直接读取持久化记录，不能在记忆服务失败时默认忽略重要约束。

6 审计与取消

授权、执行、失败、重规划和回执记录审计事件。哈希链支持本地篡改检查，具备写入权限的人仍可能同时改写记录和校验数据，因此不等于独立外部存证。界面展示执行阶段和结果，不向用户暴露模型内部推理。

停止按钮通知后台取消未提交步骤。已经提交的操作保留查询与回执入口，不能把中断显示成已撤销交易。

7 部署边界

默认只监听127.0.0.1。Docker使用非root账户、丢弃权限并启用no-new-privileges，Chroma不向宿主机暴露端口。SQLite和文件锁用于单机共享目录，多实例方案不能直接跨主机使用。本项目未实施第三方渗透测试、正式银行安全认证或完整合规审计。